NIS2 GOVERNANCE INSTRUMENT

GOV-001 | Governance Instrument | Information Management Framework

Document ID: GOV-001
Version: 1.0
Classification: Internal Use
Owner: CISO
Co-Owner: General Counsel | CFO | CEO
Approved by: Management Body — [DATE]
Review Frequency: Annual
Status: Active
Regulation: NIS2 Directive (EU) 2022/2555, Articles 20 and 21
Addresses Gaps: NIS2-G01, NIS2-G03, ISO-G02, ISO-G04

CONFIDENTIAL — FOR INTERNAL USE ONLY

1. Purpose

This Governance Instrument establishes the formal governance framework required by Articles 20 and 21 of the NIS2 Directive (EU) 2022/2555 ('NIS2'). It creates the mechanisms through which [Company Name]'s management body approves and oversees the cybersecurity risk-management programme, demonstrates that management body members receive appropriate cybersecurity training, and evidences the effectiveness of cybersecurity measures in a form available for regulatory inspection.

> **IMPORTANT:** NIS2 Article 20(1) makes management body members personally liable for failures of oversight. The formal approval and review processes in this document are the primary mechanism through which that liability obligation is discharged. Failure to maintain this instrument — or to execute the approval acts it defines — creates direct personal regulatory exposure for each management body member.

2. Scope and Applicability

This instrument applies to all members of the [Company Name] management body (Board of Directors, or equivalent governing body), the Chief Executive Officer, Chief Financial Officer, Chief Information Officer, Chief Information Security Officer, Chief People Officer, General Counsel, and any other executive who is a member of the management body as defined by NIS2.

It applies in addition to — and does not replace — any obligations already imposed by IMF-001, POL-010, SOP-010, or any other document in the IMF suite. The IMF suite constitutes the cybersecurity risk-management measures that this instrument governs.

3. Article 20 — Management Body Obligations

3.1 Annual Programme Approval

The management body shall formally approve the cybersecurity risk-management programme at least once per calendar year. Approval constitutes confirmation that the management body:

- has reviewed the Annual Programme Effectiveness Report (Section 4.2) and is satisfied that appropriate and proportionate risk-management measures are in place;
- is aware of the organisation's current risk posture, including open High and Critical risks, exceptions, and any incidents since the previous approval;
- approves the programme as constituting the 'cybersecurity risk-management measures' of [Company Name] for the purposes of NIS2 Article 21; and

- has considered any material changes to the threat environment, regulatory landscape, or organisational scope since the previous approval.

Approval Attribute	Requirement
Frequency	Annual minimum. Extra-ordinary approval required within 30 days of: a material change to the regulatory or threat landscape; a P1 security incident; a significant NIS2-reportable incident; a merger, acquisition, or major system change materially affecting the programme.
Quorum	Full management body (or quorum as defined by the governing instrument). No proxy.
Evidence	Board/management body minutes confirming approval, referencing GOV-001 by document ID and version. Minutes must be retained for a minimum of 5 years and available for regulatory inspection within 3 business days of request.
Deferral	If the annual approval window lapses without a meeting, the CISO notifies the Board Chair and General Counsel within 5 business days. Approval must occur at the earliest available meeting and the reason for delay must be documented.

3.2 Ongoing Oversight Obligations

Between annual approvals, the management body retains the following oversight obligations:

Obligation	Frequency	Evidence
Receive CISO cybersecurity briefing — current risk posture, significant incidents, regulatory developments	Quarterly at minimum	Board minutes / CISO report filed in Board papers repository
Review open High and Critical risks from POL-010 Risk Register	Quarterly (embedded in CISO briefing)	ISSG minutes — copy to Board Chair
Review any active exceptions under EXC-001 that are High or Critical residual risk	Quarterly (embedded in CISO briefing)	EXC-001 exception register extract in Board papers
Review supply chain security posture — Tier A vendor status under POL-013	Semi-annual	Vendor Risk Report in Board papers
Receive notification of any NIS2 significant incident within 24 hours of incident confirmation	As events occur	Notification record in incident log (SOP-012)

3.3 Management Body Cybersecurity Training

NIS2 Article 20(2) requires that members of the management body complete cybersecurity training sufficient to enable them to identify risks and assess cybersecurity risk-management practices. This section defines the management body training programme.

> **NOTE:** Management body training is tracked separately from the general POL-020 training tiers and is not substituted by Tier 1 all-staff training. Completion records must be individually named, dated, and available for inspection.

Training Attribute	Requirement
Audience	All management body members; CEO; CFO; CIO; CISO; CPO; General Counsel; any executive with oversight responsibility under NIS2
Format	Assessed — completion alone is not sufficient. Assessment must test identification of risk scenarios, understanding of the organisation's risk posture, and the obligations imposed by NIS2. Minimum 60-minute assessed module per year.
Content (minimum)	(a) NIS2 Article 20 personal liability obligations; (b) [Company Name] cybersecurity risk posture and open significant risks; (c) AI governance and emerging threat landscape; (d) supply chain risk and Board-level indicators; (e) the organisation's incident response obligations including NIS2 Article 23 timelines
Frequency	Annual. Onboarding training within 30 days of appointment to the management body.
Completion deadline	30 September each year for annual renewal. No extension except under EXC-001 with CISO approval.
Evidence	LMS completion record including: name, role, module name, completion date, assessment score, version of module. Retained minimum 5 years. Available for NIS2 supervisory inspection.
Failure to complete	CISO notifies Board Chair and General Counsel at 30 days overdue. Overdue status included in next ISSG and Board papers.
New management body member	Complete onboarding cybersecurity training within 30 days of appointment. Until onboarding training is complete, the new member must not approve cybersecurity risk-management measures without a written briefing from the CISO.

4. Article 21(f) — Programme Effectiveness Framework

4.1 Effectiveness Assessment Approach

NIS2 Article 21(f) requires policies and procedures to assess the effectiveness of cybersecurity risk-management measures. [Company Name] addresses this through a two-level framework:

domain-level review (annual review within each policy) aggregating into a programme-level Annual Programme Effectiveness Report.

Level	Mechanism	Output	Audience
Domain level	Annual policy review as required by each POL document. Reviews assess: are the controls operating as designed? Have exceptions increased? Has the threat/regulatory landscape changed? Is the control still proportionate?	Completed annual review section in each policy document. Issues escalated to ISSG.	CISO / Policy Owner / ISSG
Programme level	Annual Programme Effectiveness Report — aggregates domain-level outputs, KPIs/KRIs from Section 4.3, open risk and exception trends, incident volume and severity trends, training completion rates, and independent assurance findings. Presented to management body at annual approval meeting.	Annual Programme Effectiveness Report (controlled document, filed in Board papers with GOV-001 evidence pack)	Management Body / CISO

4.2 Annual Programme Effectiveness Report — Content Requirements

The Annual Programme Effectiveness Report shall be prepared by the CISO, reviewed by the ISSG, and presented to the management body. It shall contain, at a minimum:

Section	Content
1. Executive Summary	Two-page maximum. Programme health RAG status. Three most significant risks. Three most significant developments since last report. CISO attestation that the programme constitutes appropriate and proportionate measures under NIS2 Art. 21.
2. Risk Posture	Risk register summary from POL-010/SOP-010: total risks by severity, open High/Critical risks, trend vs. prior year, top 3 risks by inherent score. Treatment plan completion rate for due items.
3. Incident Summary	Volume by P-level, mean time to detect, mean time to contain, any NIS2-significant incidents, any regulatory notifications made. Trend vs. prior year.
4. Training and Awareness	Completion rates by tier (including management body tier). Phishing simulation results trend. GxP training compliance status.
5. Exception Status	Open exceptions by residual risk level. Exceptions overdue for renewal. Any exception where risk has escalated since approval.
6. Vendor Risk	Tier A and Tier B vendor assessment completion rate. Critical findings from assessments. Any vendor incidents affecting [Company Name].
7. KPI/KRI Dashboard	Key metrics from Section 4.3.
8. Independent	Summary of penetration test findings, internal audit findings, external

Section	Content
Assurance	certifications (ISO 27001 surveillance, etc.). Remediation status of prior findings.
9. Programme Changes	Material changes to the IMF suite since last report. New documents, amended policies, retired controls.
10. Forward Priorities	CISO's top 3 priorities for the next 12 months. Budget implications if any.

4.3 Programme KPIs and KRIs

Metric	Type	Definition	Target	Source
Mean Time to Detect (MTTD)	KRI	Average hours from incident occurrence to detection	<4 hours (P1)	SOP-012
Mean Time to Contain (MTTC)	KRI	Average hours from detection to containment	<8 hours (P1)	SOP-012
Vulnerability SLA compliance	KPI	% of vulnerabilities remediated within POL-017 SLA	≥95%	SOP-017
Critical/High patch timeliness	KPI	% Critical and High CVEs patched within SLA	≥98% Critical, ≥95% High	SOP-017
Management body training completion	KPI	% of named management body members with current-year assessed training	100% by 30 September	LMS
All-staff Tier 1 training completion	KPI	% of staff with current-year Tier 1 training	≥95% by deadline	LMS
Phishing click rate	KRI	% of recipients clicking simulated phishing	<5%	SOP-020
Tier A vendor assessments current	KPI	% of Tier A vendors with assessment within 12 months	100%	SOP-013
Access review timeliness	KPI	% of quarterly access reviews completed within 10 working days	100%	SOP-008
Backup restore test success	KPI	% of quarterly restore tests completed successfully	100%	SOP-016
Open High/Critical exceptions	KRI	Count of open exceptions with High or Critical residual risk	0 (target)	EXC-001
NIS2 early warning timeliness	KPI	% of NIS2-significant incidents with 24-hour early warning submitted on time	100%	SOP-012

5. IS Programme Assurance Framework

5.1 Purpose

Article 21(f) and ISO 27001 A.5.35 require independent review of the information security programme. This section defines the assurance activities, their owners, frequency, and the reporting chain to the management body.

5.2 Assurance Activities

Activity	Scope	Frequency	Provider	Output	Repor
External penetration test	Network perimeter, internet-facing applications, internal network (assumed-breach scenario), Tier 1 system interfaces	Annual minimum; additional test after major infrastructure change	CREST-accredited third party	Penetration test report with CVSS-scored findings, remediation timeline	CISO Board (summ Annua Effecti Repor
ISO 27001 surveillance audit	Full ISMS scope	Annual (between certification renewals)	Accredited certification body	Non-conformity / observation report	CISO
ISO 27001 recertification	Full ISMS scope	Every 3 years	Accredited certification body	Certification decision	CISO
Internal IS audit	Sample of 5 policies per year on a rolling cycle; 100% coverage over 3 years	Annual (phased)	Internal Audit or outsourced IS audit function	Findings report	Interna Directo → Boa Comm
GxP system IS audit	IS controls on GxP-classified systems — access, change, audit trail, backup	Annual, integrated with GxP compliance audit where possible	Compliance/ QA with Information Security	GxP IS audit findings report	Compl Directo
Threat intelligence programme review	Currency and effectiveness of threat intelligence sources, ISAC participation, CISA KEV integration	Annual, as part of POL-010 review	CISO / Information Security	Review memo filed with POL-010 annual review evidence	CISO
NIS2 supervision self-assessment	Self-assessment against NIS2 Art. 20 and Art. 21(a)–(j) using GOV-001 as the checklist	Annual, before management body approval meeting	CISO	Self-assessment scorecard	CISO (includ Annua Effecti Repor

5.3 Independent Assurance — Management Body Reporting

The management body shall receive, at minimum, the following assurance communications directly (not only through the CISO):

- Annual external penetration test summary — top findings, remediation status, residual risk accepted.
- Any ISO 27001 non-conformity at certification audit or surveillance — within 10 business days of receipt.
- Any internal IS audit finding rated High or Critical — within 5 business days of issue.
- Annual Programme Effectiveness Report — including the NIS2 self-assessment scorecard.

6. Regulatory Authority Contact Register (REF-001)

NIS2 Article 23 requires notification to the national CSIRT or national competent authority (NCA) for significant incidents. This section constitutes the Regulatory Authority and Information Sharing Contact Register (REF-001) for the IMF suite. It must be reviewed at least quarterly by the CISO and updated within 5 business days of any contact change.

IMPORTANT: The contacts in this register must be verified with Legal and, where applicable, with the relevant authority's published contact details, before this document is approved. Placeholder entries are not acceptable in the live version of this register.

Authority / Body	Jurisdiction	NIS2 Role	Contact Type	Primary Contact	Secondary Contact
[Member State National CSIRT]	[Primary EU jurisdiction]	NIS2 Art. 23 early warning and incident notification recipient	Incident reporting	[Name, role, tel, email]	[Name, role, email]
[National Competent Authority (NCA)]	[Primary EU jurisdiction]	NIS2 supervisory authority for health sector essential entities	Regulatory contact	[Name, role, tel, email]	[Name, role, email]
UK ICO	UK	GDPR (UK) Art. 33 personal data breach notification	Data breach notification	[DPA contact details from ICO website]	[Backup]
EU supervisory authority (lead)	EU	GDPR (EU) Art. 33 notification — lead supervisory authority if EU establishment	Data breach notification	[Lead SA — depends on establishment location]	[Backup]
US HHS OCR	US	HIPAA Breach Notification Rule	PHI breach notification	1-800-368-1019 / ocrportal.hhs.gov	[Company L contact]

Authority / Body	Jurisdiction	NIS2 Role	Contact Type	Primary Contact	Secondary Contact
US FDA	US	21 CFR Part 11 / GxP regulatory authority for drug/device GxP systems	GxP system incident; patient safety	[Assigned FDA contact via Legal]	[Legal]
EMA / MHRA	EU / UK	GxP regulatory authority — EU and UK	GxP system incident	[EMA/MHRA contact per Compliance/QA]	[Compliance Director]
ENISA	EU	EU Agency — voluntary incident information sharing; ENISA vulnerability database	Information sharing (voluntary)	enisa.europa.eu/ topics/incident-reporting	[CISO]
[Sector ISAC — e.g., H-ISAC for health]	International	Threat intelligence sharing	Threat intelligence	[H-ISAC member portal / duty analyst]	[CISO]
CISA (US)	US	CISA KEV source; voluntary incident reporting	Vulnerability intelligence; voluntary incident	cisa.gov/report	[CISO]

7. Document Control

Attribute	Value
Review trigger	Annual; within 30 days of any material change to NIS2 obligations or transposing national law; within 30 days of any supervision exercise finding; within 30 days of any P1 incident or NIS2-reportable incident
Related documents	IMF-001; POL-010/SOP-010; POL-012/SOP-012; POL-020/SOP-020; EXC-001; RACI-001; PLAN-001
Supersedes	Nothing — first issue
Next review date	[Date of issue + 12 months]

— End of Document —

GOV-001 v1.0 | [Company Name] | INTERNAL USE